

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

Name: K.Gokula

Reg No: 192312519

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. There port identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyse the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system.

Answer:

Analysis of the Nmap Scan Report

The Nmap scan performed on the target **192.168.1.10** identified three open ports:

- Port 22 – SSH
- Port 80 – HTTP
- Port 3306 – MySQL

The scan also detected the operating system and service versions running on the target machine. This information helps administrators identify exposed services but can also assist attackers in planning attacks.

Security Risks

1. SSH (Port 22)

SSH provides secure remote access to the system.

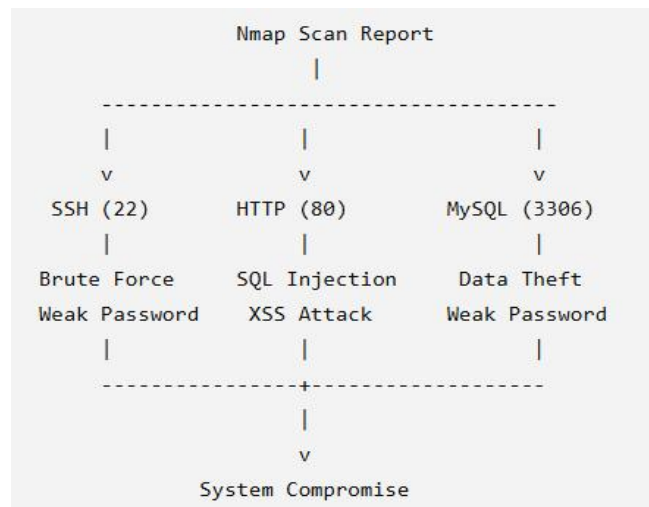
Risks

- Weak passwords can be brute-forced.
- Old SSH versions may contain known vulnerabilities.
- Attackers can gain remote administrative access.

Possible Exploitation

- Password guessing attacks.
- Exploiting outdated SSH software.

- Unauthorized remote login.



2. HTTP (Port 80)

HTTP hosts web applications.

Risks

- Unencrypted communication.
- Web application vulnerabilities.
- Exposure of sensitive information.

Possible Exploitation

- SQL Injection
- Cross-Site Scripting (XSS)
- Directory traversal
- Website defacement

3. MySQL (Port 3306)

MySQL stores application databases.

Risks

- Database exposed to the network.
- Weak database passwords.
- Unauthorized access to sensitive records.

Possible Exploitation

- Credential brute-force attacks.
- Database theft.
- Data modification or deletion.

Operating System and Service Version Detection

Nmap detected the operating system and service versions.

Security Risk

- Attackers can search public vulnerability databases for known exploits affecting the detected versions.

Recommended Security Measures

- Disable unused services.
- Change default ports where appropriate.
- Use strong and unique passwords.
- Enable Multi-Factor Authentication (MFA) for SSH.
- Restrict MySQL access to localhost or trusted IP addresses.
- Configure firewalls to block unnecessary ports.

Conclusion

The Nmap report shows that the system exposes several important services. If these services are poorly configured or outdated, attackers can gain unauthorized access, steal data, or compromise the system. Regular updates, secure configurations, and continuous monitoring significantly reduce these risks.

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. Using the Go Phish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyse the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.

Answer: Analysis of the Go Phish Report

The phishing awareness campaign produced the following results:

- 40% clicked the phishing link.
- 20% entered their login credentials.
- Several employees downloaded the malicious attachment.

These results indicate that many employees were vulnerable to social engineering attacks.

Security Weaknesses

1. Employees Clicked Phishing Links

This shows that many users failed to recognize suspicious emails.

Risk

- Malware infection.
- Credential theft.
- Redirection to fake websites.

2. Employees Entered Credentials

Employees submitted usernames and passwords to a fake login page.

Risk

- Account compromise.
- Unauthorized access.
- Data breaches.

3. Malicious Attachment Downloads

Employees downloaded harmful files.

Risk

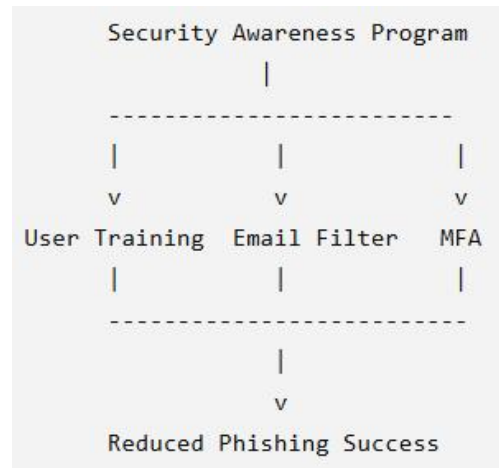
- Ransomware infection.
- Malware execution.
- System compromise.

Recommended User Awareness Programs

- Conduct regular cybersecurity awareness training.
- Teach employees how to identify phishing emails.
- Perform periodic phishing simulation campaigns.
- Educate staff about suspicious links and attachments.
- Encourage immediate reporting of suspicious emails.

Recommended Email Security Controls

- Enable spam and phishing filters.
- Implement SPF, DKIM, and DMARC.
- Scan email attachments automatically.
- Block executable attachments.
- Use URL filtering and sandboxing.



Organizational Policies

- Enforce strong password policies.
- Require Multi-Factor Authentication (MFA).
- Follow the principle of least privilege.
- Establish incident reporting procedures.
- Conduct regular security awareness assessments.

Conclusion

The Go Phish report demonstrates that employee awareness is a critical part of cybersecurity. Continuous training, secure email systems, and strong organizational policies greatly reduce the likelihood of successful phishing attacks.

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyse the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure.

Answer: Analysis of the Dig DNS Zone Transfer Report

The Dig tool successfully performed a DNS Zone Transfer (AXFR). This means the DNS server allows unauthorized users to retrieve the entire DNS zone information.

The report exposed:

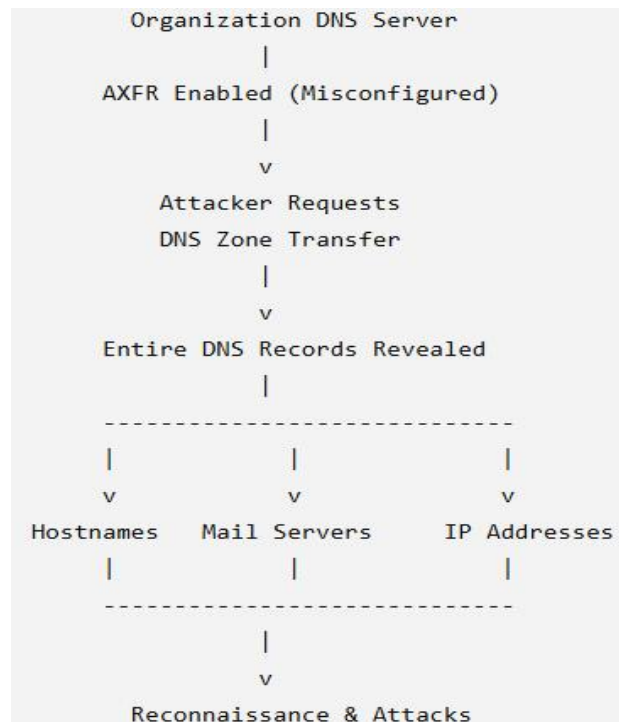
- Internal hostnames
- Mail servers
- DNS records
- Server names
- IP addresses

Security Implications

The exposed DNS information provides valuable intelligence to attackers.

Risks

- Disclosure of internal network structure.
- Identification of mail servers.
- Discovery of internal hosts.
- Easier reconnaissance for future attacks.



Possible Exploitation

Attackers can:

- Map the organization's network.
- Identify valuable servers.
- Target mail servers with phishing attacks.
- Perform vulnerability scanning.
- Launch targeted cyber-attacks.

Best Practices to Secure DNS Infrastructure

- Disable DNS Zone Transfers for unauthorized users.
- Allow AXFR only for trusted secondary DNS servers.
- Configure Access Control Lists (ACLs).
- Hide unnecessary DNS information.
- Enable DNSSEC to protect DNS integrity.

Conclusion

Allowing unrestricted DNS Zone Transfers exposes sensitive infrastructure information that attackers can use for reconnaissance. Restricting zone transfers, implementing DNSSEC, and regularly monitoring DNS servers significantly improve DNS security.